Introduction

Security Engineering
Srđan Krstić
ETH Zürich

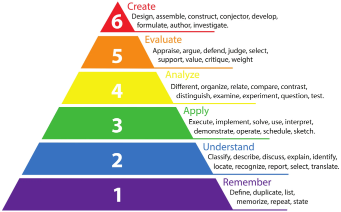
Important Information

- **Lecturers:**
  - David Basin (basin@inf.ethz.ch)
  - Srđan Krstić (srdan.krstic@inf.ethz.ch)
  - **Lecture Session:** Wednesdays, 10.15 - 12.00, CAB G 51
- **Assistants Exercise Sessions:**
  - Matthias Brun (matthias.brun@inf.ethz.ch)
  - Shabnam Ghasemirad (shabnam.ghasemirad@inf.ethz.ch)
  - Hoang Nguyen (hoang.nguyen@inf.ethz.ch)
  - Zijing Yin (zijing.yin@inf.ethz.ch)
  - **Exercise Session:** Wednesdays, 14.15 - 16.00, CAB G 51
- **Assistant Lab:**
  - Andrei Cotor (acotor@student.ethz.ch)
  - Daniel Galan (daniel.galan@inf.ethz.ch)
  - **Lab Session:** Fridays, 10.15 - 12.00, CHN D 46
- **Prerequisites:**
  - Software Engineering
  - Information Security

Syllabus

Week	Lecture	Exercises	Lab
1	Introduction		
2	Requirements Engineering		Flask
3	Modeling		
4	Model-driven Security & Privacy		OCL
5			νActionGUI
6	Secure Coding		C vulnerabilities
7			Web vulnerabilities
8	Risk Analysis		
9	Threat Modeling		**Project**
10	Security Design		
11	Code Scanning		Code scanners
12	Security Testing		Pen-testing
13			**Exam Q&A**
14	**Exam** $\longleftrightarrow$ Guest Lecture		–

Exercises, Lab, and Project



The assignments contain **conceptual** and **hands-on (lab)** exercises.

Learning goals:

- **Understand** concepts from the lectures.
- **Apply** your knowledge to solve conceptual exercises.
- **Understand** the security & privacy engineering tools.
- **Apply** your knowledge to solve hands-on exercises.
- **Apply** model-driven security & privacy to **create** a web application.

Assignments

- **Organization** For *week$_i$*:
  - before the exercise session: the i-th assignment available on Moodle.
  - in the exercise session: "pre-discuss" the i-th assignment.
    - if $i > 1$, "post-discuss" the $(i-1)$-th assignment
  - in the lab session: come with prepared questions about the hands-on part of the i-th assignment.

  Usually most time spent on post-discussion

Assignments

- **Organization** For *week*$_i$:
  - before the exercise session: the i-th assignment available on Moodle.
  - in the exercise session: "pre-discuss" the i-th assignment.
    - if $i > 1$, "post-discuss" the $(i-1)$-th assignment
  - in the lab session: come with prepared questions about the hands-on part of the i-th assignment.

    Usually most time spent on post-discussion
- Solving assignments is not mandatory, but **highly recommended**.
  - Exam questions are often based on the conceptual exercises from the assignments.
  - Hands-on exercises in the assignments are designed to prepare you for the project.

Tools

- **Modeling**: OCLpy
- **Model-driven security & privacy**: νActionGUI, Python/Flask
- **Secure coding**: GDB, OWASP WebGoat, OWASP ZAP
- **Static analysis**: FindBugs, RATS, SonarQube, Pytaint, Angr ...
- **Testing**: OWASP ZAP

We will provide you with Docker images for each of the tools.

Our research prototype, under active development. Please bear with us.

Model-Driven Security and Privacy

- ν**ActionGUI** is a new tool for developing security- and privacy-aware data-centric applications
  - E.g., *myStudies*, *Health record manager*, *Social networking site*.
- **Python/Flask** is a web development framework for Python
- Project will be done using both νActionGUI and Flask.
- **Hands-on exercises** (i.e., lab assignments) are designed to help you to familiarize with both tools.

Project

- Develop a secure and privacy-aware web application.
- Project start $\approx$ **5 November 2025** (week 8)
- Typical for this course: the project changes/improves each year
- Consists of multiple parts (usually **three parts**)
- With **1-2 weeks** available to solve each part
- Project is done **individually**
- Follow the announcements on the course Moodle page

Questions